Gerenciamento de Segurança

Introdução

Estudante, na computação em nuvem, assim como nos demais aspectos da computação, é preciso usar as melhores técnicas e processos de gerenciamento para que os recursos sejam utilizados de forma otimizada e poupem dinheiro, tempo e até mesmo para que possam ser uma vantagem para quem usa.

Mas não é só isso! A gestão deve entrar nos processos de segurança e garantir que apenas as melhores práticas estão sendo utilizadas. Assim como evolui a computação, evoluem os ataques, e desta forma a gestão deve acompanhar o progresso dos sistemas de proteção para que os ativos digitais estejam sempre adequadamente protegidos.

Dentro deste tema que vamos tratar nesta aula, você, estudante, compreenderá melhor a importância da gestão da segurança em aspectos como os planos de continuidade do empreendimento e até mesmo o BIA, o *Business Impact Analysis.*

Objetivos da aula

- Compreender a importância dos planos de continuidade;
- Conhecer os principais conceitos do BIA (*Business Impact Analysis*);
- Compreender a importância dos Testes dos Planos de Continuidade;

- Conhecer os processos e usos da recuperação de serviços de TI.

Resumo

Planos de continuidade

Até mesmo a empresa mais preparada, que atua com redundâncias para as mais diversas adversidades, precisa criar um plano para lidar com a sequência de eventos que ocorrem quando alguma catástrofe lhe atinge. Isso significa que não adianta ter sistema de sirenes que alertam de um possível incêndio se nenhum funcionário sabe que deve evacuar o prédio quando o escuta soar pelos corredores.

De acordo com a ISO 27000, (LIMA 2018), os principais objetivos de um plano de continuidade de negócios (BCP) são ajudar uma organização a lidar com desastres, reduzir perdas, aumentar a disponibilidade, segurança e confiabilidade da TI e dos negócios da organização, para fornecer suporte e qualidade.

Figura 1: Plano de continuidade de negócios.



Fonte: Lima (2018, p.29).

Algumas organizações dizem ter planos de contingência para se preparar para desastres, mas também devem pensar na continuidade, pois existem grandes diferenças entre os dois. Um plano de emergência pode ser entendido como um plano B ou um backup, ou seja, a capacidade de continuar processando informações, de operar as funções principais da empresa, em cenários de desastre.

De acordo com Lima (2018), quanto menor o tempo de recuperação das atividades da empresa, mais eficaz e confiável o PCN é, mas como esse objetivo será alcançado com o PCN? A ISO 27000 afirma que um BCP é, por definição, um plano, criado a partir de informações exclusivas de uma organização. Mais alguns planos precisam ser desenvolvidos para poder descrever os procedimentos estratégicos e operacionais do PCN. Este tipo de plano demanda uma série de etapas.

Compreender e identificar todos os componentes de TI que dão suporte às operações de negócios em todos os níveis, consiste em conhecer suas operações de negócios, os serviços e componentes de TI de sua organização e suas inter-relações. Esta etapa também pode ser

entendida como o mapeamento do ambiente de TI. Isso se deve principalmente ao foco na compreensão de como a TI se relaciona com os negócios.

A realização de análise ambiental é um dos passos mais importantes neste processo, pois dela vem o conhecimento dos riscos com os quais a empresa deve lidar e planear. E isso consiste em analisar o ambiente de TI (identificado), criar uma matriz de riscos e identificar os riscos mais críticos tanto no ambiente físico quanto no lógico. Essa avaliação de risco já indica as prováveis causas de falha nos negócios de TI e fornece um argumento de negócios para decisões de investimento em relação à continuidade dos negócios.

Para Lima (2018), é preciso fazer uma análise de impacto nos negócios, pois esta etapa é uma das mais importantes para entender completamente o impacto de sua solução de continuidade em suas operações de negócios e, mais importante, medir seu custo. Em outras palavras, mostra o impacto (tangível e intangível) da interrupção nos negócios da empresa. Com essas informações, você pode entender quanto pode investir em TI para realmente dar suporte à continuidade dos negócios do ponto de vista da análise de custo-benefício.

Em seguida, é preciso criar uma estratégia de continuação com base nas informações já coletadas sobre quais são os ativos de TI envolvidos, qual seu risco e de que forma é capaz de impactar a atividade normal do negócio. Aqui é preciso definir como a organização abordará a continuidade dos negócios. Portanto, além da preocupação da organização com soluções emergenciais, é importante pensar na continuidade do negócio.

Assim, já é possível criar o Plano de Continuidade de Negócios, e de acordo com Lima (2018), nesta fase é o momento em que uma

organização reúne todo o conhecimento sobre a relação TI x negócio e resolve ações que precisam ser tomadas para identificar crise. Organizar a tomada de decisões durante uma crise: Reúna as pessoas certas para realizar as ações necessárias para responder à crise; Defina e documente o conhecimento técnico específico para permitir que a TI restaure as operações de negócios o mais rápido possível.

Business Impact Analysis – BIA

Se refletirmos sobre a tradução da sigla BIA, que trata-se da análise do impacto nos negócios, já podemos compreender seu principal objetivo, pois com o BIA (*Business Impact Analysis*) é possível identificar nas unidades de negócios, nos departamentos e dentro dos processos, quais são os pontos críticos para a sobrevivência de uma organização em uma situação de emergência.

Conforme determina Lima (2018), o BIA ajuda na obtenção da informação sobre quais unidades de negócios e processos-chave provavelmente estarão totalmente funcionais novamente após um desastre e como isso pode acontecer. Ainda segundo o autor, o impacto nos negócios é identificado com base no pior cenário que pode ocorrer na infraestrutura do ambiente de computação em nuvem que suporta todos os processos e sistemas necessários para continuar as operações.

Figura 2: Exemplos de impactos no negócio.

Ameaça	severidade	Probabilidade	Risco	Medida de controle
Enchente	Média	Média	Estrago da água, falta de acesso	Colocar o data center em andar seguro
Blackout	Baixa	Média	Perda de dados, perda de controles de segurança	Gerador de energia. Estação elétrica auxiliar
Falha no servidor de aplicação do ERP	Alta	Alta	Parada nos processos de venda, faturamento, etc.	Site backup com base de dados duplicada

Fonte: Lima (2018, p.34).

Neste sentido, cada unidade de negócios precisa de seu BIA, feito por completo e para todos os processos operacionais. Desta forma é possível planejar e determinar qual criticidade do ambiente e o impacto de determinados eventos na organização no caso de interrupção do processamento.

O BIA também inclui o RTO (*Recovery Time Objective*), ou seja, o retorno objetivo de tempo de recuperação (ou tempo necessário para o objetivo de recuperação), e o RPO (*Recovery Point Objective*), representando o objetivo de ponto de recuperação ou objetivo de ponto de recuperação que especifica a recuperação até um ponto após uma interrupção, dos principais processos de negócios e como esses

processos são executados. Os riscos também devem ser identificados. Desta forma, temos que o BIA apresenta os seguintes objetivos:

- Estimar o impacto financeiro para cada unidade de negócio, assumindo o pior cenário.
- Estimar os impactos intangíveis (operacionais) para cada unidade de negócio, assumindo os piores tipos de cenários.
- Identificar os processos e as unidades de negócio e estimar o tempo de recuperação das informações necessárias para cada unidade de negócio. (LIMA 2018, p.35).

O escopo da BIA, conforme apresenta Lima (2018), deve considerar cada unidade de negócio e descrever a BIA, cada uma incluindo seus departamentos e seus respectivos processos executados. Dada a situação de análise do impacto em um ambiente de computação em nuvem ou infraestrutura de TI, uma pontuação ou nível deve ser determinado para determinar áreas potenciais de perda para soluções de continuidade.

Quadro 1: Faixas de perdas cumulativas (tangíveis).

Pontuação	Faixa de perda
0	Nenhuma
1	< R$ 2.000,00
2	≥ R$ 2.000,00 < R$ 7.000,00
3	≥ R$ 7.000,00 < R$ 15.000,00
4	≥ R$ 15.000,00 < R$ 25.000,00
5	≥ R$ 25.000,00 < R$ 50.000,00
6	≥ R$ 50.000,00 < R$ 100.000,00
7	≥ R$ 100.000,00 < R$ 150.000,00
8	≥ R$ 150.000,00 < R$ 250.000,00
9	≥ R$ 250.000,00 < R$ 500.000,00
10	≥ R$ 500.000,00

Fonte: Lima (2018, p.35).

Observe que no processo de preparação do BIA, as categorias de impacto e suas respectivas definições devem ser preparadas para indicar quais devem ser apresentadas no relatório, conforme o quadro a seguir:

Quadro 2: Definições das categorias de impacto

Categoria do Impacto	Definição
Perda de Receita	Perda de receita com a venda de produtos ou de serviços.
Despesas Adicionais	Serviços, equipamentos ou equipe trabalhando em tempo extra.
Legal e Regulatório	Multas, penalidades, problemas de compliance, obrigações contratuais, obrigações financeiras.
Serviço ao cliente	Encerramento ou redução de níveis de serviços (interno ou externo), operações automatizadas versus mão de obra viva.
Patrimônio da Marca	Imagem pública, relações com investidores, fatia do mercado.

Fonte: (LIMA 2018, p.37).

Portanto, essas informações são necessárias para desenvolver uma estratégia de continuidade de negócios para toda a organização. A compilar esses dados em questionários, você pode criar relatórios que permitem que todas as áreas-chave de sua organização prevejam as ações necessárias para um plano de continuidade de negócios completo e eficaz.

Testes dos Planos de Continuidade

Testar os planos de continuidade é um passo tão importante quanto criá-los, pois se algo não é testado, validado, não expressa verdadeiramente a sua assertividade. Empresas simulam incêndios para poder testar seus planos de evacuação, pois se no momento de um incêndio verdadeiro o plano é percebido como falho, equivocado, vidas podem ser perdidas.

Desta forma, os PCNs devem ser avaliados em testes confiáveis para que se saiba que existe a possibilidade de se recuperar de um desastre e permitir que a organização volte a operar de acordo com as premissas do plano. Um desligamento de energia, sem aviso formal, não pode simplesmente ser incorporado a um plano de teste PCN e o impacto ser avaliado a partir daí. Desta forma o processo de teste do PCN precisa ser coerente e estudado, registrado.

Para Lima (2018), é como um treinamento onde você explica o plano para todos os participantes. Todos os funcionários e fornecedores necessários participarão com a ajuda de moderadores. O controle de tabela deve ser feito e os planos são validados por meio de auditorias, verificações e técnicas de validação. Planejadores e moderadores participam.

Deve ser conduzido um verdadeiro plano passo a passo, onde os PCN´s são validados por meio de interações entre as equipes. Devem estar presentes os principais participantes do plano e o facilitador cuja interação está sendo testada nas reuniões conjuntas.

Com o teste funcional todos os planos relacionados às atividades selecionadas (incluindo procedimentos do provedor) são testados usando recursos reais em exercícios controlados, e neste caso, todos os funcionários, fornecedores, moderadores e observadores precisam participar.

Para Lima (2018), todas as atividades do local original serão transferidas para outro local (anunciado ou não), pois todos os funcionários, fornecedores, observadores, auditores e moderadores participarão. As empresas podem começar com o método mais fácil e tentar métodos progressivamente mais difíceis, dando um passo adiante a cada ano.

Vale ressaltar que como os exercícios e testes são tão importantes, tem a capacidade de afetar as operações diárias da empresa em questão, cabe a diretoria tomar as as decisões sobre como estes testes devem ser conduzidos, entretanto, antes de fazer essas sugestões à gerência, você deve discutir essas questões com os chefes de departamento, especialmente os do departamento de TI.

Da mesma forma, a administração deve determinar com que frequência os exercícios e testes são realizados. Geralmente uma vez por ano. Quando há mudanças significativas (quando uma nova tecnologia é introduzida, quando novos processos ou produtos são entregues, etc.), os testes devem ser feitos com mais frequência. Aqui estão algumas dicas:

Em geral a empresa deve se preocupar em garantir que todo o escopo do PCN seja testado e implementado em tempo hábil envolvendo todas

as partes interessadas. Lima (2018) defende que a preparação e coordenação de exercícios e testes são normalmente feitas por um oficial de continuidade de negócios. Todos os funcionários do departamento envolvidos em exercícios e testes devem participar. O Coordenador de Emergência é responsável por criar planos de exercícios e testes. Este plano define especificamente todos os objetivos do teste.

A empresa deve indicar se as atividades foram restabelecidas dentro dos Objetivos de Tempo de Recuperação (RTO), se todos os funcionários entenderam sua função, etc. Após a realização dos exercícios e testes, os responsáveis pela coordenação da continuidade dos negócios devem analisar os resultados, compará-los com as metas estabelecidas e reportar à alta administração.

Uma forma amplamente utilizada de recuperação de desastres, de acordo com Lima (2018), é a máquina virtual. Uma máquina virtual nada mais é do que um software que simula um computador, com memória, CPU e HD definidos de acordo com o desempenho esperado. A utilização desses tipos de soluções vem crescendo exponencialmente nas empresas, principalmente nos data centers, pois economizam espaço, melhoram o desempenho e possibilitam um rápido crescimento quando necessário. Se algo der errado, você pode restaurar sua máquina rapidamente.

Recuperação de serviços de TI

Em muitos casos, a recuperação de um serviço consome uma quantidade relevante de recursos, portanto é mais um processo que deve ser corretamente desenvolvido, descrito e aplicado. Assim, a recuperação de serviço na computação em nuvem depende muito de

quais são as opções de solução disponíveis, pois existem várias opções de recuperação para os casos de perda de serviço nas soluções computação em nuvem, que podem variar de acordo com o serviço contratado ou com o provedor.

Dentre os problemas mais comuns enfrentados estão as quedas de energia, os casos de falha na recuperação de dados ou perda de hardware. E neste sentido, os data centers têm como princípio básico a redundância de equipamentos, pois neles tudo é sempre replicado, portanto, se um dispositivo falhar, o outro pode assumir rapidamente sem falha no serviço.

Normalmente, no caso de falta de energia, segundo Lima (2018), o serviço seria retomado instantaneamente, pois a segunda rede e dois outros geradores ficariam de prontidão para evitar interrupções no serviço. Também pode ser visto como um conjunto de baterias para no-breaks (equipamento equipado com bateria para evitar picos e quedas de energia) que consegue manter todos os recursos do data center conectados.

Nesses cenários, nada é mais importante do que fazer backup e restaurar dados. Toda a segurança, autonomia e garantias dos serviços de computação em nuvem são inúteis se esses serviços não funcionarem. Atualmente, os testes de recuperação de desastres não recebem críticas consistentemente positivas no mundo dos negócios. Em uma pesquisa realizada pela Symantec (*Disaster Recovery Global Data*), os administradores deram duas respostas principais sobre o motivo de não conseguirem realizar um teste completo que abrangesse todo o cenário.

Como aplicar na prática o que aprendeu

Se você vai atuar com o BIA, saiba as melhores práticas!

Todo profissional deve buscar conhecer quais são as melhores práticas de sua profissão, e no caso da atuação de processos de continuidade e do BIA, leia o artigo de título “BIA em TI: o que é e qual sua importância?” e compreenda melhor quais são as melhores práticas que podem lhe destacar na atuação com o setor.

Conteúdo bônus

Tópicos avançados

Como é o BIA na Tecnologia da Informação?

Embora uma catástrofe ou desastre tenham a capacidade de afetar a empresa toda, na maioria dos casos de grandes proporções, é preciso compreender como este impacto ocorre dentro do TI como forma de se preparar melhor para o processo de prevenção e mitigação dos riscos que é apoiado pelo instrumento BIA.

Para saber das especificidades do BIA na TI leia o artigo sobre “BIA em TI: o que é e qual sua importância?”.

Referência Bibliográfica

LIMA, Adriano Carlos de**. Segurança na computação em nuvem**. - Editora Senac São Paulo, 2018.

Ir para questão